Berechtigungskonzept (Azure Core Platform)

Dokumentinformationen

Verantwortlicher	Bindewald, André (UIS)
Prüfungsintervall	12 Monate
Letztes Überprüfungsdatum	
Nächstes Überprüfungsdatum	
Freigegeben durch	Eric Heger
Zielgruppe	UIS
Vertraulichkeit	C2
Status	REVIEWED

Berechtigungskonzept Template

Das Berechtigungskonzept, basierend auf dem von GRS bereitgestellten Template, ist in der zentralen Ablage zu finden.
Dieses Dokument ergänzt das Standard Template um weitere zusätzliche Informationen, die sich außerhalb des im Template definierten Scope befinden.

Diese Version des Berechtigungskonzeptes befindet sich aktuell noch in der "Draft" Phase, einige hier dokumentierte Rollen und Integrationen sind ggf. noch nicht verfügbar.

Die Umsetzung erfolgt im Rahmen des Anforderungsprozesses und kann in diesem Jira Epic nachverfolgt werden:

UCLOUD-1635 - Technische Einführung des Azure Core Platform Berechtigungskonzept Version 2.0 CLOSED

Inhalt

- Zusammenfassung
- Identitäten
  - User Principal (Benutzeridentität)
  - Group Principal (Gruppenobjekt)
  - Service Principal (Dienstidentitäten)
- Verfügbarkeit in Union Access Management (UAM)
- Ebenen der Rechte-Zuordnung (Layer)
- Management von Rollen- und Rollenzuordnungen
  - Role Definition
  - Role Assignment
- Rollen
  - Cost Management Rollen
  - Übergreifende Rollen
  - Applikations-/Workload-spezifische Rollen
  - Rollen innerhalb von Applikationen/Workloads
  - Rollen für spezifische Applikations-Use cases
- Self Service Role Assignments
  - Role Assignments an "Managed Identities" der gleichen Workload Stage
  - Role Assignments an "Applikations-spezifische Entra ID Gruppen"
  - Zugelassene Rollen für den Self Service
  - Verwenden des Self Service
- Privileged Identity Management (PIM)
  - Policies
- Protokolle (Logs)

Zusammenfassung

Dieses Dokument ergänzt das Berechtigungskonzept "Azure Core Platform" um zusätzliche fachliche und technische Details.

Identitäten

Unsere Azure Plattform ist vollständig in den produktiven Entra ID Tenant "unioninvestment" integriert, alle Identitäten werden in diesem Directory verwaltet. Die folgenden Identitäts-Typen sind verfügbar:

User Principal (Benutzeridentität)

Der User Prinzipal repräsentiert eine **natürliche Person** innerhalb des Verzeichnisses. Er ist die primäre Identität für den Zugriff auf Unternehmensressourcen.

- **Identifikation:** Eindeutige Zuweisung über den *User Principal Name* (UPN), welcher als E-Mail-Adresse formatiert ist (z. B. `XZ00001@union-investment.de`).
- **Authentifizierung:** Unterstützt interaktive Anmeldeverfahren, einschließlich Multi-Faktor-Authentifizierung (MFA), Single Sign-On (SSO) und passwortlose Verfahren (z. B. Windows Hello for Business).
- **Verwendungszweck:** Zugriff auf Arbeitsplatzressourcen, E-Mail-Dienste, Applikationen und Cloud-Infrastruktur.

Grundsätzlich sind technische Identitäten vom Typ "User" nicht vorgesehen und nur in Ausnahmefällen und architektureller Freigabe zulässig.

Group Principal (Gruppenobjekt)

Group Prinzipale dienen der **logischen Bündelung** von Identitäten (Usern, anderen Gruppen oder Service-Prinzipalen) zur effizienten Verwaltung von Berechtigungen.

Grundsätzlich sind Gruppen für die Autorisierung innerhalb der Plattform zu verwenden, da hierdurch die Verwaltung durch UAM ermöglicht wird.

Die direkte Zuordnung von Rollen und Rechten ist nur in Ausnahmefällen vorgesehen, z.B. bei der Berechtigung einer System Assigned Identity.

Service Principal (Dienstidentitäten)

Dies ist die Identität für Applikationen oder Dienste. Applikationen müssen sich oft gegenüber anderen Diensten ausweisen (z. B. eine App, die Daten aus einer Datenbank liest), ohne dass ein Mensch davor sitzt und ein Passwort eintippt.

Eine **Managed Identity** ist Eine Spezialform des Service Prinzipals, bei der Azure das Prinzipal und das zugehörige Passwort/Zertifikat verwaltet.

Entra ID Service Principals werden aktuell noch nicht durch UAM unterstützt. Die Bereitstellung und Berechtigung erfolgt im Rahmen von ITSM Change Prozessen.

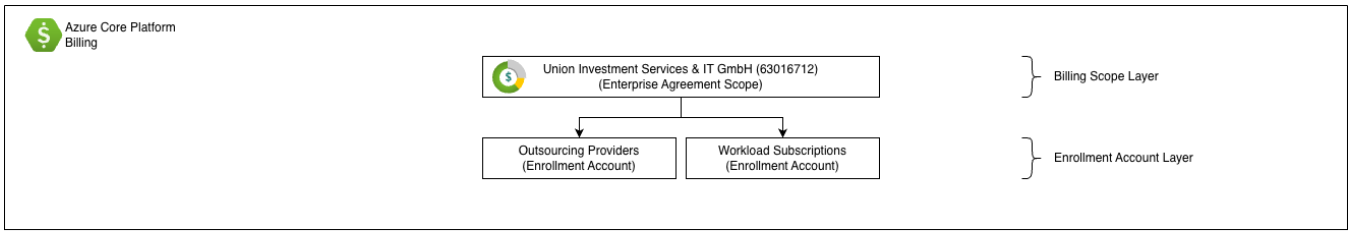
Verfügbarkeit in Union Access Management (UAM)

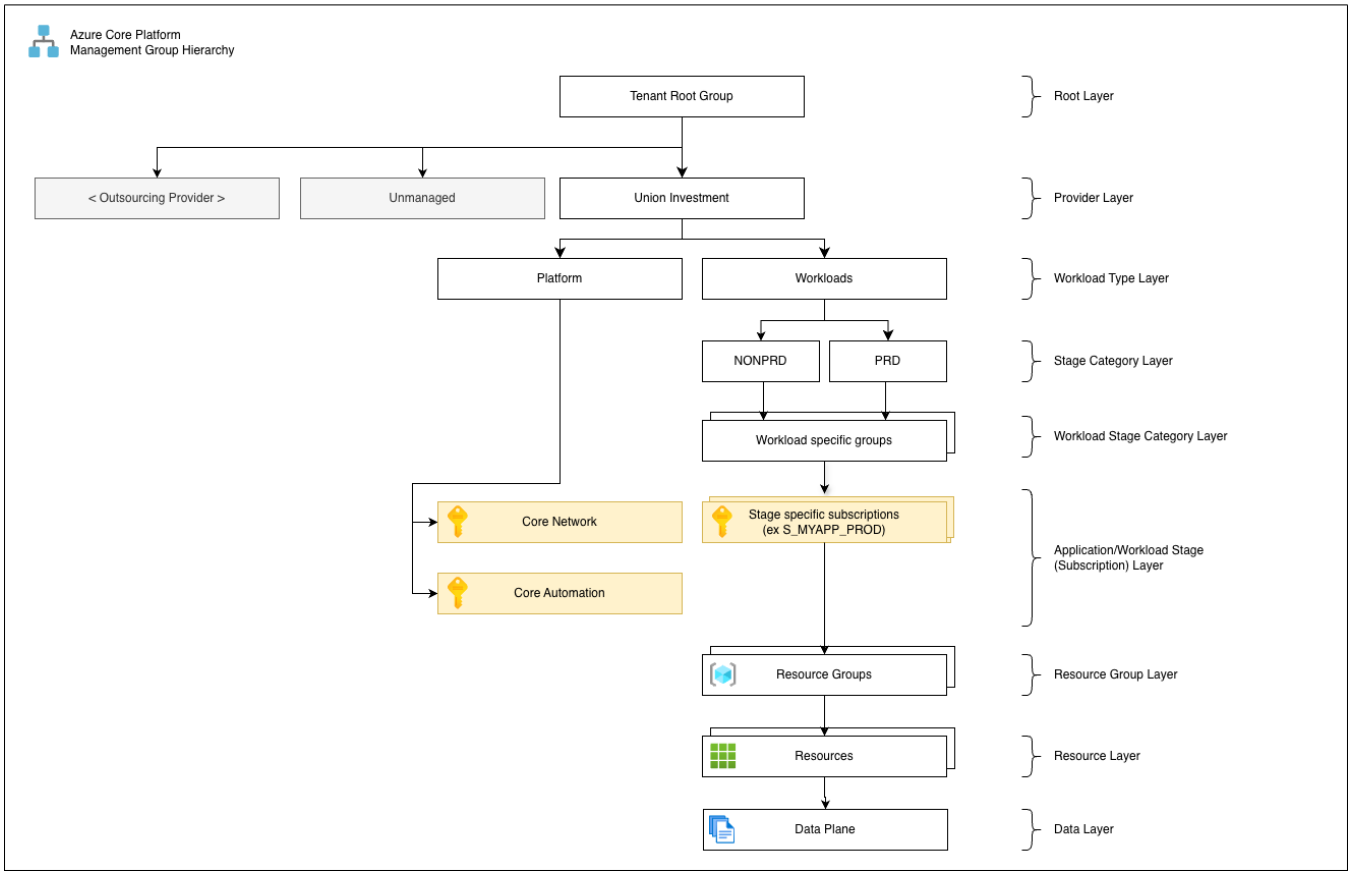
Die in der UAM Applikation "Azure Core Platform" verfügbaren Rollen sind ausschließlich für die folgenden Identitäts-Typen bestellbar:

- Cloud-only Admins
- Cloud-only Service Accounts

Ebenen der Rechte-Zuordnung (Layer)

Wir unterteilen die Azure Core Platform in Authorisierungs-Ebenen. Je Ebene ist definiert, ob und welche Rollen Zuordnungen zulässig sind.





Ebene (Layer)	Beschreibung	Verwaltet durch	Freigegeben für Rollen Zuweisungen	Self Service
Billing Scope	Billing Scopes sind Container in denen Billing Informationen, z.B. Rechnungen verwaltet werden. Ein aktives Enterprise Agreement wird als ein Billing Scope dargestellt.	IIM-CIS	Ja	Nein
Billing Account	Billing Accounts konsolidieren Subscription innerhalb eines Billing Scopes.	IIM-CIS	Nein	Nein
Root	Die erste Management Ebene des Tenants.	IIM-CIS	Ja	Nein
Provider	Diese Ebene stellt die Provider (oder Plattformen) auf unser Azure Plattform dar.	IIM-CIS	Nein	Nein
Workload Type	Unterscheidung der Workload Types, "Platform" oder "Workloads".	IIM-CIS	Nein	Nein
Stage Category	Unterscheidung der Stage Kategorie, "Non-Production" oder "Production".	IIM-CIS	Nein	Nein
Workload Stage Category	Fasst die Subscriptions eines Workloads nach Stage Kategorie zusammen, z.B. beinhaltet NONPRD/UniFoo alle nicht produktiven UniFoo Subscriptions (DEV/TEST).	IIM-CIS	Nein	Nein
Workload Stage (Subscription)	Diese Ebene beinhaltet die Workload Stages, auch Subscriptions, z.B. UniFoo/Prod	IIM-CIS	Ja	Nein
Resource Group	Resource Groups fassen Ressourcen mit gleichen Lifecycle in einer Subscription zusammen.	Applikation-/Workload	Ja	Ja
Resource	Ressourcen stellen die letzte Ebene innerhalb der Azure Management Plane dar.	Applikation-/Workload	Ja	Ja
Data	Die Daten Ebene (Data Layer), z.B. Storage Blobs, Kubernetes Pods.	Applikation-/Workload	Ja	Ja

Management von Rollen- und Rollenzuordnungen

Role Definition

Eine Rollendefinition ist eine Sammlung von Berechtigungen. Sie listet genau auf, welche Operationen (z. B. Lesen, Schreiben, Löschen) erlaubt oder verboten sind.

- **Actions:** Operationen, die erlaubt sind (z. B. `Microsoft.Compute/virtualMachines/start/action`).
- **NotActions:** Operationen, die explizit von den erlaubten Actions ausgeschlossen werden.
- **DataActions:** Berechtigungen auf Datenebene (z. B. Dateien in einem Storage Blob lesen).
- **NotDataActions**: Data Operationen, die explizit von den erlaubten Actions ausgeschlossen werden.

Für die Verwaltung und Erstellung von Rollen Definitionen werden Berechtigungen benötigt, die dem Plattformbetreiber IIM-CIS vorbehalten sind. Neue Rollen können im Zuge des Anforderungsprozesses beauftragt werden.

Nutzung von Custom und Built-in Rollen

Grundsätzlich werden die benötigten Azure Provider Operations identifiziert und zu Custom Rollen gebündelt, dies ermöglicht uns eine kontrollierte Bereitstellung von Provider Services (White-Listing).

Ausgenommen von dieser Regel sind Service spezifische Built-in Rollen, die primär für die Nutzung innerhalb eines Services (Data plane) bereitgestellt werden, z.B. Key Vault Secrets User und Storage Blob Data Reader. Übergreifende Built-in Rollen, z.B. Contributor sind im Berechtigungskonzept nicht vorgesehen.

Role Assignment

Eine Rollenzuweisung ist der operative Akt, der eine Identität mit einer Rollendefinition an einem spezifischen Bereich verknüpft. Sie besteht aus drei Kernkomponenten:

1. **Identität:** Das Subjekt, dem Zugriff gewährt wird (Benutzer, Microsoft Entra Gruppe, Service Principal oder Managed Identity).
2. **Role Definition:** Die spezifische Rolle, die zugewiesen wird (z. B. "Contributor" oder eine kundenspezifische Rolle).
3. **Scope (Geltungsbereich):** Die Grenze, innerhalb derer die Berechtigungen gültig sind.

Für die Verwaltung und Erstellung von Role Assignments auf den unteren Ebenen (Root bis Workload Stage) werden Berechtigungen benötigt, die dem Plattformbetreiber IIM-CIS vorbehalten sind. Auf den Applikations-Ebenen können Role Assignments durch den technischen Applikationsbetrieb (tAB) im Rahmen des Self Service vorgenommen werden.

Rollen

In diesem Kapitel sind die Rollen dokumentiert, die auf der Plattform genutzt werden können. Weitere technische Details sind auf der Unterseite "Verfügbare Rollen" dokumentiert.

Cost Management Rollen

Name	Ebene	UAM Applikation	UAM Modul	Kritisch	Privilegiert	SoD Klasse	Entra ID Gruppe
Enrollment Reader auf Scope "Union Investment Services & IT GmbH (63016712)"	Billing Scope	Azure Core Platform	Übergreifendes Kosten Management (Billing Scopes)	Nein	Nein	IT Infrastrukturbetrieb	AZ.CostMgmt.63016712.Reader
Enrollment Administrator auf Scope "Union Investment Services & IT GmbH (63016712)"	Billing Scope	Azure Core Platform	Übergreifendes Kosten Management (Billing Scopes)	Ja	Ja	IT Infrastrukturbetrieb	AZ.CostMgmt.63016712.Enterprise Admin

Übergreifende Rollen

Die folgenden Rollen sind übergreifende Zuordnungen. Permanente Zuordnungen ("Aktiv") gelten dauerhaft und berechtigte Zuordnungen können mittels Privileged Identity Management (PIM) bei Bedarf aktiviert werden.

Name	Ebene	UAM Applikation	UAM Modul	Kritisch	Privilegiert	SoD Klasse	Entra ID Gruppe
Reader	Root	Azure Core Platform	Übergreifende Berechtigungen (Root Ebene)	Nein	Nein	Keine SoD Relevanz	AZ.Root.Tenant.Reader
Platform Administrator	Root	Azure Core Platform	Übergreifende Berechtigungen (Root Ebene)	Nein	Ja	IT Infrastrukturbetrieb	AZ.Root.Tenant.Platform Administrator
Platform RBAC Administrator	Root	Azure Core Platform	Übergreifende Berechtigungen (Root Ebene)	Ja	Ja	IT Infrastrukturbetrieb	AZ.Root.Tenant.Platform RBAC Administrator

Data Reader	Root	Azure Core Platform	Übergreifende Berechtigungen (Root Ebene)	Nein	Nein	IT Infrastrukturbetrieb	AZ.Root.Tenant.Data Reader
Data Administrator	Root	Azure Core Platform	Übergreifende Berechtigungen (Root Ebene)	Ja	Ja	IT Infrastrukturbetrieb	AZ.Root.Tenant.Data Administrator
Billing Administrator	Root	Azure Core Platform	Übergreifende Berechtigungen (Root Ebene)	Nein	Ja	IT Infrastrukturbetrieb	AZ.Root.Tenant.Billing Administrator
Information Security Manager (ISM)	Root	Azure Core Platform	Übergreifende Berechtigungen (Root Ebene)	Nein	Ja	IT Infrastrukturbetrieb	AZ.Root.Tenant.Information Security Manager
Network Support	Root	Azure Core Platform	Übergreifende Berechtigungen (Root Ebene)	Nein	Nein	IT Netzwerkbetrieb	AZ.Root.Tenant.Network Support
Carbon Emissions Reader	Root	Azure Core Platform	Übergreifende Berechtigungen (Root Ebene)	Nein	Nein	Keine SoD Relevanz	AZ.Root.Tenant.Carbon Emissions Reader

Applikations-/Workload-spezifische Rollen

Die folgenden Rollen sind Zuordnungen innerhalb Applikations-/Workload Stage. Diese Rollen werden mittels Automatisierung in der verknüpften UAM Anwendung bereitgestellt, sodass die Freigabe der Berechtigungen dem Freigabemodell/Prozess der betroffenen Anwendung folgt.

Permanente Zuordnungen ("Aktiv") gelten dauerhaft und berechtigte Zuordnungen können mittels Privileged Identity Management (PIM) bei Bedarf aktiviert werden.

Name	Ebene	UAM Applikation	UAM Modul	Kritisch	Privilegiert	SoD Klasse	Entra ID Gruppe
Reader	Applikation /Workload Stage	{UAM Applikation des Workloads}	Azure Workload Berechtigungen	Nein	Nein	IT Infrastrukturbetrieb	AZ.Workload.{Name}.{Stage}.Reader
Data Reader	Applikation /Workload Stage	{UAM Applikation des Workloads}	Azure Workload Berechtigungen	Nein	Nein	IT Infrastrukturbetrieb	AZ.Workload.{Name}.{Stage}.Data Reader
Data Administrator	Applikation /Workload Stage	{UAM Applikation des Workloads}	Azure Workload Berechtigungen	Ja	Ja	IT Infrastrukturbetrieb	AZ.Workload.{Name}.{Stage}.Data Administrator
Information Security Manager (ISM)	Applikation /Workload Stage	{UAM Applikation des Workloads}	Azure Workload Berechtigungen	Nein	Ja	IT Infrastrukturbetrieb	AZ.Workload.{Name}.{Stage}. Information Security Manager
Application Manager (AM)	Applikation /Workload Stage	{UAM Applikation des Workloads}	Azure Workload Berechtigungen	Nein	Ja	IT Infrastrukturbetrieb	AZ.Workload.{Name}.{Stage}. Application Manager
Fachlicher Applikationsbetrieb (fAB)	Applikation /Workload Stage	{UAM Applikation des Workloads}	Azure Workload Berechtigungen	Nein	Ja	IT Infrastrukturbetrieb	AZ.Workload.{Name}.{Stage}. Fachlicher Applikationsbetrieb
Technischer Applikationsbetrieb (tAB)	Applikation /Workload Stage	{UAM Applikation des Workloads}	Azure Workload Berechtigungen	Ja	Ja	IT Infrastrukturbetrieb	AZ.Workload.{Name}.{Stage}. Technischer Applikationsbetrieb

Rollen innerhalb von Applikationen/Workloads

Grundsätzlich erfolgen Rollenzuordnungen ausschließlich auf der Ebene "Applikation/Workload Stage". Für folgende Use-cases ist die Nutzung von erweiterten Rollenzuordnungen auch auf den unteren Ebenen "Resource Group", "Resource" und "Data" zulässig:

1. Granulare Berechtigung auf datenhaltende Ressourcen, z.B. Storage Container, Datenbanken und Kubernetes Cluster
2. Granulare Berechtigung für Service Identitäten der gleichen Umgebung (Managed Identities aus der gleichen Workload Stage), z.B. Kubernetes Node erhält Zugriff auf ein Key Vault Secret

Rollen innerhalb eines Workloads sind nicht dafür vorgesehen, eigene Plattformen innerhalb eines Workloads zu implementieren!

Die Möglichkeit Rollen innerhalb eines Workloads zu vergeben, sind nicht dafür vorgesehen, ein eigenes Berechtigungskonzept auf der Management Plane zu etablieren, daher sind Rollen, die Schreibenden Zugriff auf Management Plane Ebene erteilen, nicht zulässig.

Unzulässiges Beispiel:

Neue Berechtigungsgruppe "UniFoo Kubernetes Admins", die Kubernetes Admin Zugriff auf die "UniFoo-AKS" Ressourcen Gruppe erhält.

Die Zuordnung auf dieser Ebene erfolgt selbsttätig durch den technischen Applikationsbetrieb (tAB) im Rahmen von "Self Service Role Assignments".

Die folgenden Rollen sind für Applikations-/Workload-spezifischen Ebenen freigegeben:

Name	Ebene	Kritisch	Privilegiert	Zulässige Identitäten für Role Assignments

Key Vault Certificate User	Resource Group, Resource, Data	Nein	Nein	• Service Principals der gleichen Workload Stage
Key Vault Crypto User	Resource Group, Resource, Data	Nein	Nein	• Service Principals der gleichen Workload Stage
Key Vault Secrets User	Resource Group, Resource, Data	Nein	Nein	• Service Principals der gleichen Workload Stage
Key Vault Crypto Service Encryption User	Resource Group, Resource, Data	Nein	Nein	• Service Principals der gleichen Workload Stage
Storage Blob Data Contributor	Resource Group, Resource, Data	Nein	Nein	• Service Principals der gleichen Workload Stage • Group Principals der gleichen Workload Stage
Storage Blob Data Owner	Resource Group, Resource, Data	Ja	Ja	• Service Principals der gleichen Workload Stage • Group Principals der gleichen Workload Stage
Storage Blob Data Reader	Resource Group, Resource, Data	Nein	Nein	• Service Principals der gleichen Workload Stage • Group Principals der gleichen Workload Stage
Storage Blob Tag Reader	Resource Group, Resource, Data	Nein	Nein	• Service Principals der gleichen Workload Stage • Group Principals der gleichen Workload Stage
Storage Blob Tag Writer	Resource Group, Resource, Data	Nein	Nein	• Service Principals der gleichen Workload Stage • Group Principals der gleichen Workload Stage
Storage File Data Privileged Reader	Resource Group, Resource, Data	Ja	Ja	• Service Principals der gleichen Workload Stage • Group Principals der gleichen Workload Stage
Storage File Data SMB Share Contributor	Resource Group, Resource, Data	Nein	Nein	• Service Principals der gleichen Workload Stage • Group Principals der gleichen Workload Stage
Storage File Data SMB Share Elevated Contributor	Resource Group, Resource, Data	Ja	Ja	• Service Principals der gleichen Workload Stage • Group Principals der gleichen Workload Stage
Storage File Data SMB Share Reader	Resource Group, Resource, Data	Nein	Nein	• Service Principals der gleichen Workload Stage • Group Principals der gleichen Workload Stage
Storage Table Data Contributor	Resource Group, Resource, Data	Nein	Nein	• Service Principals der gleichen Workload Stage • Group Principals der gleichen Workload Stage
Storage Table Data Reader	Resource Group, Resource, Data	Nein	Nein	• Service Principals der gleichen Workload Stage • Group Principals der gleichen Workload Stage
Storage Queue Data Contributor	Resource Group, Resource, Data	Nein	Nein	• Service Principals der gleichen Workload Stage • Group Principals der gleichen Workload Stage
Storage Queue Data Message Processor	Resource Group, Resource, Data	Nein	Nein	• Service Principals der gleichen Workload Stage • Group Principals der gleichen Workload Stage
Storage Queue Data Message Sender	Resource Group, Resource, Data	Nein	Nein	• Service Principals der gleichen Workload Stage • Group Principals der gleichen Workload Stage
Storage Queue Data Reader	Resource Group, Resource, Data	Nein	Nein	• Service Principals der gleichen Workload Stage • Group Principals der gleichen Workload Stage

Azure Service Bus Data Receiver	Resource Group, Resource, Data	Nein	Nein	• Service Principals der gleichen Workload Stage
Azure Service Bus Data Sender	Resource Group, Resource, Data	Nein	Nein	• Service Principals der gleichen Workload Stage
App Configuration Data Reader	Resource Group, Resource, Data	Nein	Nein	• Service Principals der gleichen Workload Stage
Monitoring Metrics Publisher	Resource Group, Resource, Data	Nein	Nein	• Service Principals der gleichen Workload Stage
AcrPull	Resource Group, Resource, Data	Nein	Nein	• Service Principals der gleichen Workload Stage
AcrPush	Resource Group, Resource, Data	Nein	Nein	• Service Principals der gleichen Workload Stage
AzureML Data Scientist	Resource Group, Resource, Data	Nein	Nein	• Service Principals der gleichen Workload Stage

Rollen für spezifische Applikations-Use cases

Die folgenden Rollen sind nur für spezifische Use cases verfügbar und können nur nach expliziter Freigabe genutzt werden. Grundsätzlich ist eine Zuordnung dieser Rollen nur für technische Identitäten vorgesehen.

Name	Ebene	UAM Applikation	UAM Modul	Kritisch	Privilegiert	SoD Klasse	Entra ID GruppeVeeam Backup and Replication Computer Account
Veeam Backup and Replication Computer Account	Applikation/Workload Stage	Keine bestellbare Rolle	Keine bestellbare Rolle	Ja	Ja	Keine SoD Relevanz	Keine bestellbare Rolle
Qualys Tenant Connector	Übergreifende Berechtigungen (Root Ebene)	Keine bestellbare Rolle	Keine bestellbare Rolle	Nein	Nein	Keine SoD Relevanz	Keine bestellbare Rolle

Self Service Role Assignments

IIM-CIS stellt die Applikations/Workload Umgebungen für die Nutzer der Plattform bereit (Azure Subscriptions), die technische und fachliche Verantwortung von Ressourcen innerhalb dieser Container liegt auf Seiten des Application Managers (AM) und bei den durch ihn beauftragten Einheiten (z.B. IIM-CIS tAB).

Die Vergabe von zusätzlichen Berechtigungen auf diesen Ressourcen (Ebene Resource Group, Resource, Data) obliegt demnach der Rolle "Technischer Applikationsbetrieb (tAB)".

IIM-CIS stellt dem technischen Applikationsbetrieb (tAB) das Recht zur Verfügung, um freigegebene Rollen an freigegebene Identitäten zu vergeben, wir sprechen von "Self Service Role Assignments".

Technisch ist der Self Service mit Azure Role Assignment Conditions (ABAC) realisiert, jeder Assignment Versuch durchläuft unterschiedliche Konditionen, die alle erfüllt werden müssen:

1. Erlaubte Identität
2. Zugelassene Rolle

In den folgenden Unterkapiteln sind die erlaubten Use cases dokumentiert.

Role Assignments an "Managed Identities" der gleichen Workload Stage

Managed Identities der gleichen Workload Stage (z.B. UniFoo DEV) können durch den technischen Applikationsbetrieb (tAB) auf Ressourcen innerhalb der gleichen Workload Stage berechtigt werden.

Ein typischer Beispiel Use Case ist es, die Managed Identity einer Azure Function auf einen Storage Account zu berechtigen.

Role Assignments an "Applikations-spezifische Entra ID Gruppen"

Für einige Use cases ist es notwendig, Applikations-spezifische Gruppen direkt auf die Azure Ressourcen oder auf der Daten Ebene zu berechtigen, z.B. wenn eine Gruppe "App.UniFoo.DEV.Users" auf ein File Share zugreifen sollen. Für diese Szenario ist es möglich, im Rahmen des ITSM Change Prozesses Gruppen für den Self Service freigeben zu lassen.

Um eine Gruppe für den Self Service freigeben zu lassen, müssen folgende Kriterien zutreffen:

1. Die Gruppe wurde vorab durch den Application Manager (AM) in UAM angelegt
2. Es handelt sich um eine Applikations-spezifische Gruppe "App.UniFoo.*"
3. Die Gruppe ist eindeutig der Applikations zuzuorden (Workload UniFoo zu App.UniFoo.*)
4. Die Gruppe gehört zur gleichen Stage wie der Ziel Workload (Workload UniFoo DEV zu App.UniFoo.DEV)

Schreibende Management Plane Berechtigungen sind nicht für Entra ID Gruppen zugelassen.

Zugelassene Rollen für den Self Service

Die zugelassenen Rollen sind unter "Rollen innerhalb von Applikationen/Workloads" dokumentiert.

Beantragen von neuen Rollen oder Anpassungen an bestehenden Rollen

Neue Rollen, bzw. Anpassungen an bestehenden Rollen können im Rahmen des Anforderungsprozesses bei IIM-CIS beauftragt werden.

Verwenden des Self Service

Die Erstellung und Anpassungen an Self Service Role Assignments ist durch die Applikations-/Workload-spezifische Rolle "Technischer Applikationsbetrieb (tAB)" möglich. Hierzu können standard Azure Portal Funktionen, die Azure Management API oder Automation Tools (Terraform /Bicep) verwendet werden.

Die Verantwortung für die Erstellung und Wiederherstellung von Self Service Role Assignments obliegt dem technischen Applikationsbetrieb (tAB).

Durch die Anwendung verwaltete Role Assignments sind im Berechtigungskonzept der jeweiligen Anwendung zu dokumentieren.

Privileged Identity Management (PIM)

Mittels "Azure Privileged Identity Management (PIM)" implementieren wir ein "Just-in-Tme (JIT)" Zugriffsmodell. Rollen vom Zuordnungstyp "Berechtigt" müssen vor der Nutzung aktiviert werden. Die Anforderungen, die in diesem Rahmen erfüllt werden müssen, hängen von der verknüpften PIM Role Policy ab.

Die Art der Zuordnung und verknüpfte PIM Policy ist der Unterseite "Verfügbare Rollen" dokumentiert.

Policies

Standard Policy für Non-Production Systeme (PIM-01)

	Konfigurierter Wert
Maximaler Aktivierungszeitraum	12 Stunden
Begründung erforderlich	Ja
Ticket Informationen (z.B. Incident Nummer) erforderlich	Nein
Genehmigung erforderlich	Nein
Genehmiger	N/A
Permanente Zuordnung (Berechtigt) erlaubt	Ja
Berechtigte Zuordnungen laufen ab nach	Nie
Permanente Zuordnung (Aktiv) erlaubt	Nein
Aktive Zuordnungen laufen ab nach	Nie
Multi Factor bei aktiven Zuordnungen erforderlich	Ja
Begründung bei neuen aktiven Zuordnungen erforderlich	Ja
E-Mail Benachrichtigungen	Nein

Standard Policy für Production Systeme (PIM-10)

	Konfigurierter Wert
Maximaler Aktivierungszeitraum	12 Stunden
Begründung erforderlich	Nein
Ticket Informationen (z.B. Incident Nummer) erforderlich	Ja
Genehmigung erforderlich	Nein
Genehmiger	N/A
Permanente Zuordnung (Berechtigt) erlaubt	Ja
Berechtigte Zuordnungen laufen ab nach	Nie
Permanente Zuordnung (Aktiv) erlaubt	Nein
Aktive Zuordnungen laufen ab nach	Nie
Multi Factor bei aktiven Zuordnungen erforderlich	Ja
Begründung bei neuen aktiven Zuordnungen erforderlich	Ja
E-Mail Benachrichtigungen	Nein

Policy für die Freigabe von privilegierten Operationen durch den Application Manager (PIM-11)

	Konfigurierter Wert
Maximaler Aktivierungszeitraum	1 Stunde
Begründung erforderlich	Ja
Ticket Informationen (z.B. Incident Nummer) erforderlich	Ja
Genehmigung erforderlich	Ja
Genehmiger	Application Manager (AM) der Workload Stage (Subscription)
Permanente Zuordnung (Berechtigt) erlaubt	Ja
Berechtigte Zuordnungen laufen ab nach	Nie
Permanente Zuordnung (Aktiv) erlaubt	Nein
Aktive Zuordnungen laufen ab nach	Nie
Multi Factor bei aktiven Zuordnungen erforderlich	Ja
Begründung bei neuen aktiven Zuordnungen erforderlich	Ja
E-Mail Benachrichtigungen	Nein

Protokolle (Logs)

Logs werden mittels Azure Diagnostic Settings (forciert mittels Azure Policy) an das SIEM System "Sentinel" übertragen und aufbewahrt. Die Analyse dieser Logs erfolgt in der Oberfläche des SIEM Workspaces.

Log Typ	Sentinel Instanz	Sentinel Table (Datenmodell)	Aufbewahrungsdauer	Ingestion Intervall

Azure Activity Logs • CRUD Operationen an Ressourcen • Erstellen von neuen Rollen • Anpassungen von bestehenden Rollen • Aktivieren von Rollen via PIM • Erstellen/Löschen von neuen Rollen Zuordnungen (z.B. Self Service)	UnionInvestment	AzureActivity	2 Jahre (definiert im SIEM System)	< 5 min